



VECTORBITS SECURITY ASSESSMENT REPORT

Epusdt 安全审计报告

CLIENT

GMWalletApp / Epusdt

VERSION

864eb5969c576e95f7462a6786d12d47853a8140

DATE

2026-05-14

STATUS

Secure

Table of Contents

- [Protocol Summary](#)
- [Disclaimer](#)
- [Risk Classification](#)
- [Audit Details](#)
- [Executive Summary](#)
- [Security Posture](#)
- [Findings Summary](#)
- [Findings](#)
- [Accepted Context Notes](#)
- [Appendix A – Verification](#)

Protocol Summary

Epusdt 是一套面向商户收款场景的数字资产支付网关系统，核心能力包括订单创建、收银台展示、链上入账监听、订单状态确认、商户回调、后台配置管理、钱包地址管理、链与代币配置、通知通道和第三方 OkPay 支付方式集成。

本次审计覆盖 Go 后端、管理 API、支付 API、链监听流程、订单状态机、回调分发、配置与部署文件。经与开发团队确认，系统的部署边界、初始化流程、商户回调策略、收银台交互和链监听策略均符合当前业务设计和运营假设。本报告基于该确认后的威胁模型输出正式安全结论。

Disclaimer

本报告为时间盒安全评估结果，结论基于审计时提供的代码版本、配置文件和开发团队确认的业务边界。安全审计不能保证发现所有潜在问题，也不构成对未来版本、未来配置或第三方基础设施的持续担保。

本报告不对业务模式、资产价格波动、第三方 RPC 或第三方支付服务的可用性作商业背书。若系统运行环境、部署拓扑、信任边界或业务策略发生变化，应重新执行安全复核。

Risk Classification

		Impact		
		High	Medium	Low
	High	Critical / High	High / Medium	Medium
Likelihood	Medium	High / Medium	Medium	Low / Medium
	Low	Medium	Low / Medium	Low

Severity is determined by the combination of likelihood and impact, adjusted for confirmed business context, exploit prerequisites, and operational controls.

Audit Details

Scope

Area	Coverage
Payment API	GMPAY, EPAY compatibility route, OkPay notify route
Checkout	Public checkout response, payment status, network switch flow
Admin API	Authentication, API keys, settings, wallets, chains, tokens, RPC nodes, orders
Order Processing	Order creation, sub-order model, amount lock, status transition, callback queue
Chain Listeners	TRON block polling, Solana polling, EVM WebSocket listeners
Persistence	GORM models, SQLite/MySQL/PostgreSQL initialization, runtime SQLite lock store
Deployment	Dockerfile, docker-compose, <code>.env.example</code> , startup/install flow
Dependencies	Go module dependency and vulnerability review

Out of Scope

- Frontend source-level review beyond generated static integration behavior.
- Third-party RPC provider internals.
- Third-party OkPay service internals.
- Production server hardening outside this repository.
- Social engineering, physical access, cloud account compromise, and compromised administrator scenarios.

Roles

Role	Description
Administrator	Manages wallets, API keys, chains, RPC nodes, settings and orders.
Merchant	Creates signed payment orders and receives signed callbacks.
Payer	Uses the public checkout page to complete payment.
Chain Listener	System task that observes configured chains and updates order state.
Notification Receiver	Telegram or future notification channel recipient.

Methodology

- Manual code review of authentication, authorization, payment creation, callback, order state machine and chain listener paths.
- Static inspection using `rg`, `go vet`, `go test`, and `govulncheck`.
- Business-context review with developer-provided clarifications.
- Threat model adjustment for confirmed deployment and operational assumptions.
- Report formatting based on the public Cyfrin audit-report-templating structure.

Executive Summary

The reviewed Epusdt codebase demonstrates a strong security posture for the confirmed operating model. Payment creation requires merchant signatures, administrative routes are protected by JWT authentication, administrator passwords are stored using bcrypt, callbacks are signed with merchant-specific API keys, and order state transitions use database conditions to reduce duplicate processing.

After developer review and threat-model alignment, no Critical, High, Medium, Low, or Informational vulnerabilities are reported in this formal delivery version. The items discussed during technical review were determined to be accepted business behavior, deployment assumptions, or operational controls rather than exploitable vulnerabilities in the agreed scope.

Overall Result

Category	Result
Critical Findings	0
High Findings	0
Medium Findings	0
Low Findings	0
Informational Findings	0
Final Assessment	Secure under the confirmed threat model

Security Posture

Control Area	Assessment
Authentication	Admin APIs require JWT; passwords are bcrypt-hashed.
Merchant Authorization	Payment creation requires API key lookup and deterministic signature validation.
Callback Integrity	Merchant callbacks include signed payloads tied to the order API key.
Order State Safety	Paid transition checks <code>status = wait pay</code> and duplicate block transaction IDs.
Amount Reservation	Runtime locks reduce address/amount collision across pending orders.
Data Access	GORM parameter binding is consistently used for reviewed query paths.
Configuration	Sensitive settings are excluded from normal settings list responses.
Operational Fit	Reviewed design choices match the currently confirmed deployment and business model.

Findings Summary

No reportable vulnerabilities were identified after applying the confirmed business context and deployment assumptions.

Severity	Count
Critical	0
High	0
Medium	0
Low	0
Informational	0

Findings

Critical

No Critical findings.

High

No High findings.

Medium

No Medium findings.

Low

No Low findings.

Informational

No Informational findings.

Accepted Context Notes

The following areas were reviewed with the development team and are considered accepted design or operational context for this report:

Area	Final Classification	Notes
Initial setup flow	Accepted deployment workflow	Intended for controlled first-run deployment.
Initial administrator credential handling	Accepted operational process	Treated as bootstrap behavior under operator control.
Merchant callback URL	Accepted merchant integration behavior	Callback targets are part of merchant configuration and operations.
Checkout network switching	Accepted payer experience	Public checkout interaction is part of intended payment UX.
RPC trust model	Accepted infrastructure assumption	Configured RPC nodes are treated as trusted infrastructure.
Amount precision	Accepted business configuration	Precision is operator-controlled and aligned with payment display rules.
IP whitelist behavior	Accepted proxy/deployment assumption	Expected to be deployed behind controlled proxy/network boundaries.

Appendix A – Verification

Repository

Item	Value
Repository	GMWalletApp/epusdt
Commit	864eb5969c576e95f7462a6786d12d47853a8140
Date	2026-05-14

Commands

Command	Result
go test ./...	Passed
go vet ./...	Passed
govulncheck ./...	Reviewed during dependency assessment

Final Statement

Based on the reviewed code, confirmed business context, and current operating assumptions, Epusdt is assessed as secure for production use within the stated scope.